# ETSI TR 104 285 V1.1.1 (2026-08)



TECHNICAL REPORT

**Methods for Testing & Specification (MTS);**
**Device Security Passport**

Reference
DTR/MTS-TST12DevSecPas

Keywords
device, IoT, security, testing

***ETSI***

650 Route des Lucioles
F-06921 Sophia Antipolis Cedex - FRANCE

Tel.: +33 4 92 94 42 00 Fax: +33 4 93 65 47 16

Siret N° 348 623 562 00017 - APE 7112B
Association à but non lucratif enregistrée à la
Sous-Préfecture de Grasse (06) N° w061004871

***Important notice***

The present document can be downloaded from the
ETSI Search & Browse Standards application.

The present document may be made available in electronic versions and/or in print. The content of any electronic and/or print versions of the present document shall not be modified without the prior written authorization of ETSI. In case of any existing or perceived difference in contents between such versions and/or in print, the prevailing version of an ETSI deliverable is the one made publicly available in PDF format on ETSI deliver repository.

Users should be aware that the present document may be revised or have its status changed, this information is available in the Milestones listing.

If you find errors in the present document, please send your comments to the relevant service listed under Committee Support Staff.

If you find a security vulnerability in the present document, please report it through our Coordinated Vulnerability Disclosure (CVD) program.

***Notice of disclaimer & limitation of liability***

The information provided in the present deliverable is directed solely to professionals who have the appropriate degree of experience to understand and interpret its content in accordance with generally accepted engineering or other professional standard and applicable regulations.
No recommendation as to products and services or vendors is made or should be implied.
No representation or warranty is made that this deliverable is technically accurate or sufficient or conforms to any law and/or governmental rule and/or regulation and further, no representation or warranty is made of merchantability or fitness for any particular purpose or against infringement of intellectual property rights.
In no event shall ETSI be held liable for loss of profits or any other incidental or consequential damages.

Any software contained in this deliverable is provided "AS IS" with no warranties, express or implied, including but not limited to, the warranties of merchantability, fitness for a particular purpose and non-infringement of intellectual property rights and ETSI shall not be held liable in any event for any damages whatsoever (including, without limitation, damages for loss of profits, business interruption, loss of information, or any other pecuniary loss) arising out of or related to the use of or inability to use the software.

***Copyright Notification***

No part of this document may be reproduced in any form, by any means and in any media, without the prior written authorization of ETSI and except as expressly permitted below.
By way of exception and when the document is a normative deliverable (European Standard (EN), Technical Specification (TS), Group Specification (GS) or ETSI Standard (ES)), ETSI authorizes to reproduce and incorporate into products, services and technical documentation only those extracts (e.g. templates) that are strictly necessary for the technical implementation of the normative deliverable, to ensure compliance with the latter.
Nothing in this notice shall be construed as limiting any mandatory exceptions to copyright provided by applicable law.

© ETSI 2026.
All rights reserved.

# Contents

Intellectual Property Rights ..... 4
Foreword ..... 4
Modal verbs terminology ..... 4
Executive summary ..... 4
Introduction ..... 5
1 Scope ..... 6
2 References ..... 6
2.1 Normative references ..... 6
2.2 Informative references ..... 6
3 Definition of terms, symbols and abbreviations ..... 8
3.1 Terms ..... 8
3.2 Symbols ..... 8
3.3 Abbreviations ..... 8
4 State of the art of device descriptors ..... 9
4.1 Bill of Material (BOM) ..... 9
4.1.1 Introduction ..... 9
4.1.2 Software Bill of Material (SBOM) ..... 10
4.1.3 Hardware Bill of Material (HBOM) ..... 11
4.1.4 Cryptography Bill of Material (CBOM) ..... 12
4.2 Manufacturer Usage Description (MUD) ..... 12
4.3 Vulnerability Information Exchange Formats ..... 13
4.3.1 Vulnerability Exploitability Exchange Format (VEX) ..... 13
4.3.2 Vulnerability Disclosure Report (VDR) ..... 14
4.4 Security Assessment Frameworks ..... 15
4.4.1 Open Security Control Assessment Language (OSCAL) ..... 15
4.4.2 Security Content Automation Protocol (SCAP) ..... 17
5 Rationale for a device security passport ..... 18
5.1 Limitations of existing device security descriptors ..... 18
5.2 Need for an integrated and lifecycle-aware approach ..... 18
5.3 Design principles of a Device Security Passport ..... 18
5.4 Considered alternatives and design choices ..... 19
6 Device Security Passport specification ..... 19
6.1 Concept and objectives ..... 19
6.2 Device Security Passport lifecycle ..... 20
6.3 Stakeholders and roles ..... 21
7 DOSS: Using the DSP for supply chain management ..... 22
7.1 DOSS overview ..... 22
7.2 The role of the DSP in the DOSS project ..... 23
7.3 DSP data model ..... 23
8 Role of the Device Security Passport in regulatory context ..... 25
8.1 Alignment with the Cyber Resilience Act (CRA) ..... 25
8.2 Alignment with the NIS2 directive ..... 26
8.3 Alignment with the CSA ..... 27
9 Lessons learned and recommendations ..... 27
History ..... 29

# Intellectual Property Rights

## Essential patents

IPRs essential or potentially essential to normative deliverables (European Standard (EN), Technical Specification (TS), Group Specification (GS) or ETSI Standard (ES)) may have been declared to ETSI. The declarations pertaining to these essential IPRs, if any, are publicly available for **ETSI members and non-members**, and can be found in ETSI SR 000 314: *"Intellectual Property Rights (IPRs); Essential, or potentially Essential, IPRs notified to ETSI in respect of ETSI standards"*, which is available from the ETSI Secretariat. Latest updates are available on the ETSI IPR online database.

Pursuant to the ETSI Directives including the ETSI IPR Policy, no investigation regarding the essentiality of IPRs, including IPR searches, has been carried out by ETSI. No guarantee can be given as to the existence of other IPRs not referenced in ETSI SR 000 314 (or the updates on the ETSI Web server) which are, or may be, or may become, essential to the present document.

## Trademarks

The present document may include trademarks and/or tradenames which are asserted and/or registered by their owners. ETSI claims no ownership of these except for any which are indicated as being the property of ETSI, and conveys no right to use or reproduce any trademark and/or tradename. Mention of those trademarks in the present document does not constitute an endorsement by ETSI of products, services or organizations associated with those trademarks.

**DECT™**, **PLUGTESTS™**, **UMTS™** and the ETSI logo are trademarks of ETSI registered for the benefit of its Members. **3GPP™**, **LTE™** and **5G™** logo are trademarks of ETSI registered for the benefit of its Members and of the 3GPP Organizational Partners. **oneM2M™** logo is a trademark of ETSI registered for the benefit of its Members and of the oneM2M Partners. **GSM**® and the GSM logo are trademarks registered and owned by the GSM Association.

# Foreword

This Technical Report (TR) has been produced by ETSI Technical Committee Methods for Testing and Specification (MTS).

# Modal verbs terminology

In the present document "**should**", "**should not**", "**may**", "**need not**", "**will**", "**will not**", "**can**" and "**cannot**" are to be interpreted as described in clause 3.2 of the ETSI Drafting Rules (Verbal forms for the expression of provisions).

"**must**" and "**must not**" are **NOT** allowed in ETSI deliverables except when used in direct citation.

# Executive summary

The increasing complexity of digital supply chains and the growing regulatory pressure on cybersecurity have highlighted the need for improved mechanisms to manage, share and reuse device security information throughout the lifecycle. Current practices rely on a fragmented ecosystem of security descriptors, tools and documents that are often disconnected, difficult to maintain and poorly suited for automation. The present document analyses the concept of a Device Security Passport (DSP) as a unifying, machine-readable mechanism to aggregate and reference security-related artefacts associated with connected devices. The DSP is presented as a lifecycle-aware construct capable of supporting supply-chain transparency, continuous security management and regulatory compliance, while preserving existing standards, ownership models and responsibilities. The present document reviews the state of the art of security descriptors, introduces the DSP concept and lifecycle, and describes its concrete instantiation in the DOSS project. The applicability of the DSP to regulatory frameworks such as the Cyber Resilience Act, the NIS2 Directive and the EU Cybersecurity Act is analysed, highlighting its potential to support transparency, evidence reuse and continuous compliance. Based on the experience gained, the present document identifies key lessons learned and outlines recommendations for future standardization and research. Overall, the present document demonstrates that the DSP is a viable and promising approach to improve trust, traceability and automation across device supply chains.

# Introduction

Digital products and connected devices are increasingly embedded in complex and dynamic ecosystems involving multiple stakeholders across global supply chains. Manufacturers, system integrators, operators and service providers each contribute to the security posture of a device at different stages of its lifecycle. At the same time, cybersecurity threats are becoming more frequent and sophisticated, while regulatory frameworks are imposing stricter obligations related to transparency, vulnerability management and lifecycle support.

In response to these challenges, a growing number of security descriptors and standards have emerged, including components inventory, network behaviour profiles, vulnerability disclosure formats and risk reporting mechanisms. While these artefacts address specific aspects of device security, they are typically developed and managed in isolation. As a result, security information is fragmented across multiple documents, formats and repositories, making it difficult to obtain a consistent and up-to-date view of a device's security posture.

This fragmentation is further exacerbated by the dynamic nature of security information. Vulnerabilities, configurations and operational contexts evolve continuously after deployment, requiring mechanisms that support updates, traceability and accountability over time. Traditional documentation-based approaches are poorly suited to this task, as they rely heavily on manual processes and human interpretation.

In parallel, regulatory pressure is increasing. New European frameworks, such as the Cyber Resilience Act (CRA) [i.1], the Network and Information Systems 2 Directive (NIS2) [i.2] and the EU Cybersecurity Act (CSA) [i.3], introduce lifecycle-oriented obligations for manufacturers and operators, including transparency requirements, vulnerability management processes and post-market support obligations. Meeting these requirements using ad hoc documentation and disconnected artefacts introduces significant overhead for manufacturers and operators and limits the potential for automation.

These challenges highlight the need for a unified approach to managing device security information across the entire lifecycle. The Device Security Passport (DSP) is proposed as a response to this need. Rather than introducing yet another standalone descriptor, the DSP acts as an aggregation layer that links existing security artefacts while preserving their original formats and ownership. By providing a single logical entry point to security information, the DSP improves visibility, supports automation and enables continuous security assurance.

# 1 Scope

The present document focuses on presenting the results, observations and lessons learned derived from the analysis and application of the Device Security Passport (DSP) concept in real project environments. In particular, it examines its instantiation within the DOSS project, which addresses security challenges in complex device supply chains with a focus on lifecycle-oriented security management and information sharing. The present document analyses how the DSP can be used as a unifying mechanism to support transparency, traceability and automation across the device lifecycle, and discusses its applicability to emerging regulatory and certification frameworks. The present document does not define normative requirements, but rather provides technical insights and experience-based observations intended to inform future standardization and research activities.

# 2 References

## 2.1 Normative references

Normative references are not applicable in the present document.

## 2.2 Informative references

References are either specific (identified by date of publication and/or edition number or version number) or non-specific. For specific references, only the cited version applies. For non-specific references, the latest version of the referenced document (including any amendments) applies.

NOTE: While any hyperlinks included in this clause were valid at the time of publication, ETSI cannot guarantee their long-term validity.

The following referenced documents may be useful in implementing an ETSI deliverable or add to the reader's understanding, but are not required for conformance to the present document.

[i.1] Regulation (EU) 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act).

[i.2] Directive (EU) 2022/2555 of the European Parliament and of the Council of 14 December 2022 on measures for a high common level of cybersecurity across the Union, amending Regulation (EU) No 910/2014 and Directive (EU) 2018/1972, and repealing Directive (EU) 2016/1148 (NIS 2 Directive).

[i.3] Regulation (EU) 2019/881 of the European Parliament and of the Council of 17 April 2019 on ENISA (the European Union Agency for Cybersecurity) and on information and communications technology cybersecurity certification and repealing Regulation (EU) No 526/2013 (Cybersecurity Act).

[i.4] National Telecommunications and Information Administration (NTIA) (2021): "The Minimum Elements For a Software Bill Of Materials (SBOM) Pursuant to Executive Order 14028 on Improving the Nation's Cybersecurity".

[i.5] Cybersecurity and Infrastructure Security Agency CISA: "Hardware Bill of Materials (HBOM) Framework for Supply Chain Risk Management", September 25, 2023.

[i.6] IBM: "CBOM: Cryptography Bill of Materials" June 29, 2023.

[i.7] CycloneDX: "Machine Learning Bill of Materials (ML-BOM)".

[i.8] CycloneDX: "Manufacturing Bill of Materials (MBOM)".

[i.9] CycloneDX: "Operations Bill of Materials (OBOM)".

[i.10] CycloneDX: "Software as a Service (SaaSBOM)".

[i.11] ISO/IEC 5962:2021: "Information technology — SPDX® Specification V2.2.1".

[i.12] ECMA-424: "CycloneDX Bill of materials specification", December 2025.

[i.13] ISO/IEC 19770-2:2015: "Information technology — IT asset management. Part 2: Software identification tag".

[i.14] IETF RFC 8520 (March 2019): "Manufacturer Usage Description Specification", E. Lear, D. Romascanu, and R. Droms.

[i.15] IETF RFC 7950 (August 2016): "The YANG 1.1 Data Modeling Language", M. Bjorklund.

[i.16] IETF RFC 9761 (April 2025): "Manufacturer Usage Description (MUD) for TLS and DTLS Profiles for Internet of Things (IoT) Devices", T. Reddy.K, D. Wing, B. Anderson.

[i.17] IETF RFC 9472 (October 2023): "A YANG Data Model for Reporting Software Bills of Materials (SBOMs) and Vulnerability Information", E. Lear, S. Rose.

[i.18] S. Sebastio, S. Beena, S. Matheu, R. Atoui and A. Skarmeta: "Bolstering Up Smart Products Cybersecurity (Re-)Certification with Manufacturer's Evidence", 2025 IEEE International Conference on Smart Computing (SMARTCOMP), Cork, Ireland, 2025, pp. 270-275, doi: 10.1109/SMARTCOMP65954.2025.00085.

[i.19] A. Molina Zarca, J. Bernal Bernabé, J. Ortíz, A. Skarmeta: "D2.5 Policy-based Definition and Policy for Orchestration Final Report", ANASTACIA Project, 2018.

[i.20] NIST SP 1800-15 (2019): "Securing Small-Business and Home Internet of Things Devices".

[i.21] CISA: "Minimum Requirements for Vulnerability Exploitability eXchange (VEX)", 2023.

[i.22] CycloneDX: "Vulnerability Exploitability eXchange (VEX)".

[i.23] OASIS (2025): "Common Security Advisory Framework Version 2.1".

[i.24] GitHub: "OpenVEX" March 10, 2026.

[i.25] NIST SP 800-161r1: "Cybersecurity Supply Chain Risk Management for Systems and Organizations", Boyens, Jon M, 2022.

[i.26] CycloneDX: "Vulnerability Disclosure Report (VDR)".

[i.27] NIST: "OSCAL V1.2.0 Reference".

[i.28] Garcia, Jesus (06/09/2023): "EUROSCAL -Paving the Road towards Automated Cybersecurity Certification in Europe (Whitepaper)".

[i.29] NIST SP 800-126r4 ipd: "Technical Specification for the Security Content Automation Protocol (SCAP)", 2025.

[i.30] CVE Foundation: "Common Vulnerabilities and Exposures".

[i.31] NIST: "CCE Platform listing", 2015.

[i.32] NIST Interagency Report 7695: "Common Platform Enumeration: Naming Specification Version 2.3", 2011, Cheikes, Brant, David Waltermire, and Karen Scarfon.

[i.33] FIRST Forum of Incident Response and Security Teams: "Common Vulnerability Scoring System: Specification Document", 2023.

[i.34] NIST Interagency Report 7275 (Revision 4): "Specification for the Extensible Configuration Checklist Description Format (XCCDF) Version 1.2", Waltermire, David, Charles Schmidt, Karen Scarfone, and Neal Ziring.

[i.35] OVAL Community: "The OVAL Community Guidelines 5.12.2 Documentation", 2024.

[i.36] NIST Interagency Report 7694: "Specification for the Asset Reporting Format 1.1", Halbardier, Adam, David Waltermire, and Mark Johnson.

[i.37] DOSS Project: "Deliverable D6.1 Integrated IoT Supply Chain Architecture", Marton, Anna, 2026.

[i.38] Matheu, S., & Skarmeta Gómez, A: "One Passport to Govern Them All: Bringing Order to IoT Security and Compliance" In: Jo, H., Shin, S., Skarmeta, A., You, I. (eds.) Mobile Internet Security. MobiSec 2025. Sapporo, Japan, December 16–18, 2025. Communications in Computer and Information Science (CCIS), vol. 3053. Springer, Singapore (2026).

NOTE: Please note that at the time of publication of the present document, the specific paper in which the figure appears is not yet publicly available, although a DOI has already been assigned.

[i.39] IETF RFC 4122 (July 2005): "A Universally Unique IDentifier (UUID) URN Namespace", P. Leach, M. Mealling, R. Salz.

[i.40] NIST SP 800-53: "Security and Privacy Controls for Information Systems and Organizations".

[i.41] ISO/IEC 27001: "Information security, cybersecurity and privacy protection — Information security management systems — Requirements".

# 3 Definition of terms, symbols and abbreviations

## 3.1 Terms

Void.

## 3.2 Symbols

Void.

## 3.3 Abbreviations

For the purposes of the present document, the following abbreviations apply:

| | |
|---|---|
| ACL | Access Control Lists |
| AI | Artificial Intelligence |
| AP | Assessment Plan |
| AR | Assessment Results |
| ARF | Asset Reporting Format |
| ASV | Architecture Security Validator |
| BOM | Bill Of Materials |
| CBOM | Cryptography Bill Of Materials |
| CCE | Common Configuration Enumeration |
| CISA | Cybersecurity and Infrastructure Security Agency |
| CPE | Common Platform Enumeration |
| CRA | Cyber Resilience Act |
| CSA | Cyber Security Act |
| CSAF | Common Security Advisory Framework |
| CT | Component Tester |
| CVE | Common Vulnerabilities and Exposures |
| CVSS | Common Vulnerability Scoring System |
| DCT | Digital Cybersecurity Twin |
| DHCP | Dynamic Host Configuration Protocol |
| DSP | Device Security Passport |
| DSPP | Device Security Passport Platform |
| DSS | Data Security Standard |

| | |
|---|---|
| ECSO | European Cyber Security Organisation |
| EUCS | European Cybersecurity Certification Scheme for Cloud Services |
| genDSP | generic DSP |
| HBOM | Hardware Bill Of Materials |
| ICT | Information and Communications Technology |
| ID | Identifier |
| IDSP | Instance-level DSP |
| IoT | Internet of Things |
| IP | Internet Protocol |
| IT | Information Technology |
| JSON | JavaScript Object Notation |
| LD | Linked Data |
| MBOM | Manufacturing BOM |
| MLBOM | Machine Learning BOM |
| MSPL | Medium-level Security Policy Language |
| MUD | Manufacturer Usage Description |
| NIS2 | Network and Information Systems Directive 2 |
| NIST | National Institute of Standards and Technology |
| NTIA | National Telecommunications and Information Administration |
| OBOM | Operations BOM |
| ObP | Onboarding Platform |
| OSCAL | Open Security Control Assessment Language |
| OVAL | Open Vulnerability and Assessment Language |
| OWASP | Open Worldwide Application Security Project |
| PCI | Payment Card Industry |
| POA&M | Plan of Actions and Milestones |
| PoC | Proof of Concept |
| SaaSBOM | Software-as-a-Service BOM |
| SBOM | Software Bill Of Materials |
| SCAP | Security Content Automation Protocol |
| SDLC | Software Development Life Cycle |
| SDN | Software Defined Network |
| SP | Special Publication |
| SPDX | Software Package Data Exchange |
| SSP | System Security Plan |
| SWID | Software Identification |
| URL | Uniform Resource Locator |
| UUID | Universally Unique Identifier |
| VDR | Vulnerability Disclosure Report |
| VEX | Vulnerability Exploitability Exchange |
| XCCDF | Extensible Configuration Checklist Description Format |
| XML | Extensible Markup Language |
| YAML | Yet Another Markup Language |
| YANG | Yet Another Next Generation |

# 4 State of the art of device descriptors

## 4.1 Bill of Material (BOM)

### 4.1.1 Introduction

A Bill Of Materials (BOM) is a structured inventory listing all components, subcomponents, and materials required to build, deploy, and operate a product or system. BOMs provide transparency, traceability, and risk management across software, hardware, and cyber-physical supply chains.

There are several specialized BOM types. Software BOMs (SBOMs) [i.4] capture software components and dependencies; Hardware BOMs (HBOMs) [i.5] enumerate physical components and assemblies; and Cryptography BOMs (CBOMs) [i.6] track cryptographic assets such as keys, certificates, and algorithms. Other BOMs serve more specialized contexts:

- Machine Learning BOMs (MLBOM) [i.7] cover models, datasets, and training pipelines;
- Manufacturing BOMs (MBOMs) [i.8] document production and assembly processes;
- Operations BOMs (OBOMs) [i.9] describe configurations and operational systems; and
- Software-as-a-Service BOMs (SaaS-BOMs) [i.10] represent cloud-based applications and services.

This clause focuses on SBOMs, HBOMs, and CBOMs, as they constitute the generic, basic BOMs applicable across most digital systems. Understanding these three types provides the basis for supply chain transparency, security, and compliance, while specialized BOMs extend these principles to domain-specific use cases.

### 4.1.2 Software Bill of Material (SBOM)

A Software Bill Of Materials (SBOM) [i.4] is a comprehensive and structured inventory that details all the components used to build and support a software product. It includes libraries, modules, frameworks, and dependencies, as well as machine learning models and datasets that may be embedded in or required for the software to operate. By providing clear visibility into the internal composition of software, an SBOM enhances transparency, strengthens security and compliance, and supports operational reliability throughout the software lifecycle.

The EU Cyber Resilience Act (CRA), Article 3, Section 37 [i.1], defines an SBOM as "a formal record containing details and supply chain relationships of components included in the software elements of a product with digital elements." This formal definition underscores its importance as a foundational mechanism for establishing trust, traceability, and accountability in the software supply chain. An SBOM allows organizations to understand exactly what their software is made of - from open-source components to proprietary code - and provides essential insights into vulnerabilities, license obligations, and component provenance. This transparency enables development, operations, and security teams to identify and mitigate risks efficiently while maintaining compliance with evolving regulatory and industry standards.

Typically, an SBOM is generated during the build phase of the Software Development Life Cycle (SDLC), capturing an exact snapshot of all components that make up a given release. This snapshot represents not only the dependencies and libraries compiled into the final product but also the metadata required to verify their integrity, origin, and security posture. The process of creating an SBOM generally involves identifying all software components, associating them with relevant metadata such as version, license, and supplier information, and representing this data in a standardized format that enables interoperability between systems and tools. Once generated, the SBOM is shared with stakeholders - developers, vendors, auditors, and regulators - to promote transparency and facilitate collaboration across the supply chain.

Modern development and security pipelines have integrated SBOM generation as an automated task, ensuring that each software build produces a verifiable and up-to-date record of its composition. These SBOMs can then be consumed by vulnerability scanners, compliance systems, and asset management tools to detect known weaknesses or license conflicts. Because software components evolve over time, maintaining an accurate SBOM requires continuous updates as dependencies change, versions are upgraded, or outdated elements are removed. This ongoing maintenance ensures that the SBOM remains a reliable reference for both operational and security management.

The structure and representation of SBOMs follow internationally recognized standards designed to ensure consistency, interoperability, and auditability. According to the U.S. National Telecommunications and Information Administration (NTIA) [i.4], the three primary and interoperable SBOM formats are:

- Software Package Data Exchange (SPDX®), standardized as ISO/IEC 5962 [i.11], which provides a comprehensive framework for documenting license obligations, verifying security attributes, and improving supply-chain transparency. SPDX® defines key mandatory fields such as package name, version, license, supplier, and cryptographic checksum, enabling reliable identification and verification of software components.

- CycloneDX [i.12], developed by the OWASP Foundation, is optimized for application security and supply-chain risk management. It supports detailed representation of components, dependencies, licenses, and known vulnerabilities, and is extensible to specialized domains such as SaaSBOMs (for cloud services), HBOMs (for hardware), and ML-BOMs (for machine learning artifacts).

- Software Identification (SWID) Tags, standardized as ISO/IEC 19770-2 [i.13], complement these formats by providing machine-readable metadata to identify installed software in enterprise environments.

While all three standards fulfil the core principles of transparency and interoperability, their scope and expressiveness differ. SPDX is widely used in compliance and licensing contexts, CycloneDX is favoured for vulnerability and risk management, and SWID tags excel in enterprise asset tracking and inventory use cases.

In practice, the SBOM has evolved into a key enabler of cybersecurity, compliance, and digital trust. It functions simultaneously as a technical artifact, a governance mechanism, and a regulatory instrument. By providing a verifiable record of software composition and provenance, SBOMs allow organizations to accelerate vulnerability remediation, ensure legal and licensing conformity, and strengthen the integrity of their digital products. As software supply chains grow in complexity and regulatory expectations intensify, the SBOM stands as a foundational mechanism for sustaining the resilience, transparency, and accountability of the digital ecosystem.

### 4.1.3 Hardware Bill of Material (HBOM)

A Hardware Bill Of Materials (HBOM) [i.5] is a formal, structured inventory that lists every physical component, subassembly, and material used in the manufacture of a product, along with the way these components are physically connected or assembled. Each entry in the HBOM typically includes metadata such as component name, supplier or vendor, part number or type, version or revision identifier, manufacturing details, and references to external documentation (for example, datasheets, mechanical drawings, or compliance certifications). Beyond simple listing, an HBOM may also capture relationships e.g. how each component is packaged, mounted, or electrically/structurally interconnected in the final assembly.

As modern systems increasingly integrate hardware, firmware, and software, the HBOM complements and interacts with the SBOM to provide full-stack visibility across the digital and physical layers of a product. This alignment enables comprehensive supply chain intelligence, facilitating the identification of dependencies, vulnerabilities, and compliance risks throughout the system lifecycle.

The HBOM plays a crucial role in supply chain management. By maintaining a precise inventory of hardware components, organizations can ensure that all parts are properly sourced, validated, and tracked. This traceability is fundamental in detecting counterfeit or malicious parts, identifying vulnerable or obsolete components, and managing supply disruptions. Without an HBOM, it becomes challenging to trace the origins or lineage of hardware components, which can pose significant security and reliability risks, especially in critical systems such as telecommunications, infrastructure, medical devices, or industrial control systems.

HBOMs also assist with obsolescence management, by flagging components approaching end-of-life or becoming unsupported. They support warranty and liability resolution, by providing clarity on which components are in use and how they were connected. In sustainability and circular economy efforts, HBOMs help with component reuse, recycling, and material traceability, allowing organizations to plan for disassembly, end-of-life recycling, or ecological compliance obligations. HBOM data can be used to demonstrate compliance with governmental or industry sourcing regulations, such as restrictions on materials from certain regions, use of conflict minerals, or manufacturing origin requirements.

In terms of standardization and interoperability, two complementary frameworks currently guide HBOM implementation. The CycloneDX specification [i.12], developed by the OWASP Foundation, extends its established SBOM data model to incorporate hardware components as part of its "xBOM" family. This unified schema allows the same machine-readable format to describe hardware, firmware, and software elements, ensuring consistency and facilitating integration across tools and ecosystems. CycloneDX HBOM supports the representation of hardware components, firmware images, configurations, and their interconnections, and it provides mechanisms such as BOM-Link for cross-referencing between related BOMs (for example, linking an HBOM to its corresponding SBOM).

In parallel, the U.S. Cybersecurity and Infrastructure Security Agency (CISA) has developed the HBOM Framework for Supply Chain Risk Management [i.5], which provides a taxonomy of hardware data elements, a set of recommended naming conventions, and practical guidance on how HBOM data should be structured and exchanged. CISA's framework defines several use-case categories such as compliance, security, and supply availability, and specifies which subsets of data fields are relevant to each. It emphasizes consistency, interoperability, and repeatability, ensuring that HBOMs from different suppliers can be compared and integrated effectively across the supply chain.

### 4.1.4 Cryptography Bill of Material (CBOM)

A Cryptography Bill Of Materials (CBOM) [i.6] is a structured, machine-readable model designed to identify, manage, and track cryptographic assets and their dependencies within a system. It provides a comprehensive inventory of cryptographic components, including algorithms, keys, certificates, protocols, and associated libraries, as well as metadata necessary to verify their origin, validity, and compliance with security policies.

The CBOM serves as a foundation for cryptographic risk management. By mapping the relationships between cryptographic assets and their dependent components, it enables organizations to assess risks, detect vulnerabilities, and ensure that cryptographic implementations adhere to applicable standards and regulatory requirements. This visibility is particularly critical for maintaining compliance with evolving cybersecurity policies and for supporting the transition to post-quantum cryptography.

A key feature of the CBOM is its ability to distinguish between "implements" dependencies (e.g. the libraries or modules that implement cryptographic algorithms and "uses" dependencies), the applications or components that rely on those algorithms. This distinction allows organizations to understand not only which algorithms are present, but also how they are applied across different parts of the system, improving accuracy in risk assessments, vulnerability analysis, and compliance reporting.

The CBOM plays a central role in enabling cryptographic agility. By providing visibility into all cryptographic implementations, organizations can quickly identify and replace weak, deprecated, or vulnerable algorithms, rotate expired keys, update certificates, and deprecate unsafe protocols. CBOM also facilitates ongoing management of cryptographic policies, ensuring that all assets comply with internal and external security standards, industry best practices, and regulatory guidance.

In terms of standardization and integration, the CBOM is designed as an extension of the CycloneDX SBOM standard [i.12]. Using CycloneDX's BOM-Link mechanism, an external CBOM or a subset of its components can be referenced in an SBOM, establishing traceability between cryptographic elements and the software or hardware systems that use them. This modular approach enables CBOMs to be maintained independently while remaining connected to broader software or system supply chain representations, supporting holistic governance, auditability, and lifecycle management.

By adopting CBOMs, organizations gain an actionable framework to manage cryptographic risk, ensure alignment with security policies, and prepare for future cryptographic transitions. CBOMs complement other supply chain artifacts, such as SBOMs and HBOMs, enabling end-to-end visibility of software, hardware, and cryptographic dependencies across complex digital systems.

## 4.2 Manufacturer Usage Description (MUD)

The Manufacturer Usage Description (MUD) is an IETF standard specification (IETF RFC 8520 [i.14]) introduced in 2019 to bolster the security of Internet of Things (IoT) devices. MUD aims to reduce the attack surface of IoT devices by providing a standardized method for manufacturers to communicate the expected network behaviour of their devices.

MUD uses a JSON-based structure that details the device's expected communication patterns and network access requirements. When a device connects to a network, it provides a MUD URL embedded in the device firmware, DHCP options, or X.509 certificates. This URL points to the MUD file, typically hosted by the manufacturer or a trusted third party. The network's MUD manager retrieves the MUD file, translates it and enforces the described policies via the network's security infrastructure, such as firewalls or SDN controllers. Policies described in the MUD file are enforced, limiting the device's access to only necessary resources. If the MUD file is updated, the network can adjust the policies dynamically to reflect the changes.

In particular, the network behaviour is expressed in the form of policies or Access Control Lists (ACLs) based on the Yet Another Next Generation (YANG) standard [i.15]. The MUD model is composed of two main containers: "mud" and "acls". The first one specifies high level information about the MUD profile, such as the MUD URL in which the MUD file is located (field "mud-url"), when it expires ("cache-validity"), when it was created ("last-update"), and its version ("mud-version"), as well as information about the device, such as the model ("model-name") and firmware/software revision ("firmware-rev", "software-rev"). Finally, this container enumerates the ACLs restricting the communications from/to the device, "to-device-policy" and "from-device-policy". Then, the second container describes the details of the ACLs. Although the definition of the ACLs is based on the YANG data model for network ACLs, it has been augmented by the MUD standard to define more expressive restrictions. For example, the terms "manufacturer" and "same-manufacturer" enable the definition of policies to allow or deny the interaction with devices from the same manufacturer. Other fields allow referencing network components (e.g. "controller" or "local-networks") without the need to know the associated IP addresses.

Beyond the basic functionalities defined in IETF RFC 8520 [i.14], MUD has been extended to address more specialized requirements. For instance, IETF RFC 9761 [i.16] extends the MUD specification to incorporate (D)TLS profile parameters, enabling network security services to detect unexpected (D)TLS usage that may indicate unauthorized software or malware on an endpoint. IETF RFC 9472 [i.17] introduces an extension to MUD that allows manufacturers to specify how SBOM can be retrieved. Broader extensions have been proposed in the context of EU projects such as CERTIFY [i.18], where a module incorporating Medium Security Policies Language (MSPLs) [i.19] was introduced into the MUD framework. This enhancement provides finer-grained control over device network behaviour, supporting advanced security policies and significantly improving the overall protection of IoT ecosystems.

In addition, the concept of MUD has been extended to include threat signalling capabilities through the so-called threat Manufacturer Usage Description (threat MUD), introduced by the National Institute of Standards and Technology (NIST) [i.20], While it shares a structural similarity with the conventional MUD format, the threat MUD is designed as a mitigation tool, specifying external sites to and from which network traffic should be restricted due to their association with a particular threat. Unlike standard MUD files, which are typically developed by device manufacturers and define permitted communication patterns, the threat MUD does not provide a list of allowed sites nor establish rules for local network traffic. Instead, it is intended to be created by a threat intelligence provider and focuses on identifying and restricting malicious or suspicious communications.

In general, the strength of the MUD lies on its ability to enhance IoT security by dynamically enforcing network policies. This allows networks to quickly adapt to device updates, new threats, or changes in expected behaviour, providing proactive and automated security management for connected devices.

## 4.3 Vulnerability Information Exchange Formats

### 4.3.1 Vulnerability Exploitability Exchange Format (VEX)

Security scanners often flag components in software as potentially vulnerable, but in many cases, the product may not actually be affected. This could be because the vulnerable component is not used in the product, has already been patched, or cannot be exploited in context. The purpose of a Vulnerability Exploitability eXchange (VEX) [i.21] is to reduce these false alarms by providing authoritative statements about the actual impact of known vulnerabilities on a product. VEX documents are typically issued by the software vendor or third parties and indicate whether a specific vulnerability truly affects the product, is mitigated, fixed, under investigation, or not applicable.

EXAMPLE: A software vendor may discover that a new CVE affects a dependency used in their product. Even before a patch is issued by the component's supplier, the vendor can communicate through a VEX document whether the vulnerability impacts their product, whether any mitigations exist, or whether further investigation is ongoing. Once a patch is applied, a new VEX statement can clarify that the vulnerability has been addressed. This enables security scanners and organizations to focus on real risks and avoid unnecessary alerts.

Statements play a central role in VEX. Statements are assertions that connect a product, a vulnerability, and the impact status of the given vulnerability on the given product. Another key part of VEX is time, as it matters when statements are made. VEX documents typically contain a sequence of statements, each overriding, but also enriching the previous ones with new information. Each statement has an associated time defined either by an explicit timestamp attached to the statement or derived implicitly from containing structures.

VEX has two widely known formats:

- CycloneDX VEX [i.22]; and
- Common Security Advisory Framework (CSAF) VEX [i.23].

In addition, the open-source community, led by the Linux Foundation, is actively working on a standard called OpenVEX [i.24], which aims to be minimal, compliant with the SBOM and VEX efforts of CISA, and agnostic to different SBOM formats. OpenVEX documents follow a minimal JavaScript Object Notation for Linked Data (JSON-LD) format, capturing essential requirements defined by the VEX working group (coordinated by CISA).

A VEX document consists of two parts:

- the document metadata; and
- a collection of statements.

The metadata part contains information about the context and the author of the VEX document, and it has a timestamp and a version field as well. The metadata part is followed by a set of statements. Each statement contains the CVE ID of a vulnerability, the ID of product or products potentially affected by the vulnerability, and the impact status of the vulnerability in relation to the given product(s). Statements may also contain a timestamp that indicates the time at which the information expressed in the statement was known to be true, and a field containing the time when the statement was last updated.

A VEX statement provides the impact status of the vulnerabilities with respect to the products listed in the statement. The status labels can be the following:

- not_affected (meaning that no remediation is required regarding this vulnerability), affected (meaning that actions are recommended to remediate or address the vulnerability), fixed (meaning that the product versions listed in the statement contain a fix for the vulnerability); and
- under_investigation (meaning that it is not yet known whether the listed product versions are affected by the vulnerability).

A not_affected status requires the addition of a justification field to the statement that explains why the product is not affected by the vulnerability (e.g. the product includes built-in protections or features that prevent exploitation of the vulnerability).

### 4.3.2 Vulnerability Disclosure Report (VDR)

Vulnerability Disclosure Report (VDR) is a structured document that records and communicates the discovery of a security vulnerability in a software product or component. According to NIST SP 800-161 [i.25], a VDR is defined as follows:

"Enterprises, where applicable and appropriate, may consider providing customers with a Vulnerability Disclosure Report (VDR) to demonstrate proper and complete vulnerability assessments for components listed in SBOMs. The VDR should include the analysis and findings describing the impact (or lack of impact) that the reported vulnerability has on a component or product. The VDR should also contain information on plans to address the CVE. Enterprises should consider publishing the VDR within a secure portal available to customers and signing the VDR with a trusted, verifiable, private key that includes a timestamp indicating the date and time of the VDR signature and associated VDR."

This definition highlights the formal role of the VDR in modern vulnerability management. A VDR not only documents the vulnerability itself but also provides an authoritative assessment of its impact (or absence thereof) on a particular product or component. Supported by CycloneDX VDR [i.26], it typically contains technical details, analysis of risk, and recommended mitigation measures. By publishing the VDR securely and signing it with a trusted digital signature, organizations can ensure the integrity and authenticity of the report, fostering trust with customers and stakeholders.

While VEX focuses on communicating the exploitability status of known vulnerabilities in the context of a specific product, the VDR serves a complementary but fundamentally different purpose. The VDR provides a comprehensive technical account of the vulnerability itself, including detailed descriptions, affected components, potential impact, and recommended mitigation or remediation measures. It addresses both known and previously unknown vulnerabilities, ensuring that organizations and their customers have a complete understanding of the security issue. In contrast, VEX only deals with known vulnerabilities and reports whether a particular product or component is affected, mitigated, fixed, or not impacted.

## 4.4 Security Assessment Frameworks

### 4.4.1 Open Security Control Assessment Language (OSCAL)

The Open Security Controls Assessment Language (OSCAL) [i.27] is a framework developed and continually updated by the NIST to standardize and streamline the documentation, assessment, and automation of security controls in information systems. OSCAL is designed to facilitate compliance with various security frameworks by providing a machine-readable format for security documentation. The MEDINA project supported the standardization of OSCAL in Europe (EUROSCAL) and has succeeded to integrate Cloud Controls as defined in the European Cybersecurity Certification Scheme for Cloud Services (EUCS) [i.28] with OSCAL. This initiative has already provided a Proof of Concept (PoC), mapping EUCS to OSCAL's Catalog Model. In 2025, the European Cyber Security Organisation (ECSO) also launched a task force focused on the usage of OSCAL for compliance automation.

OSCAL uses a set of data models expressed in XML, JSON, and YAML formats, ensuring compatibility with different data exchange standards. It includes models for catalogues, profiles, system security plans, assessment plans and results. This structured approach allows organizations to automate compliance tasks, reducing manual effort and enhancing consistency.

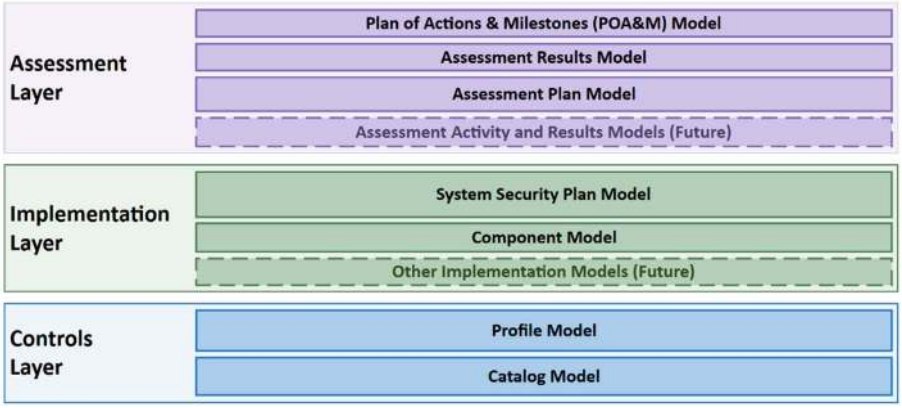



**Figure 1: Overview of OSCAL models (Source: [i.27])**

The OSCAL architecture is structured around three primary layers that work together to ensure comprehensive security documentation and compliance processes (Figure 1):

1) **Control Layer:** The Control Layer provides a repository of standardized control definitions and compliance guidelines, such as those specified in NIST SP 800-53 [i.40] and ISO/IEC 27001 [i.41]. This layer includes two primary models that provide a structured approach to defining and managing security controls, ensuring they are comprehensive, customizable, and aligned with organizational needs:

   a) The **Catalog Model** is used to express and organize security controls in a machine-readable format. This model comprises several key components. The controls are the core elements that detail specific security requirements. Each control includes statements that describe what the control aims to achieve. Additionally, the model incorporates parameters, which are variables within the controls that can be customized according to specific implementation needs. The model also includes references to related controls, guidelines, or standards, as well as objectives that the controls aim to achieve. Finally, the model defines assessment methods for evaluating the effectiveness of the controls.

   b) The **Profile Model** allows for the selection, organization, and tailoring of a specific set of controls to meet particular needs. This model includes several important components. The import function allows profiles to import controls from catalogues or other profiles, facilitating reuse and customization. The modify function enables the alteration of imported controls to fit specific requirements. Controls can be organized into logical groups for easier management. Additionally, the parameters defined in the Catalog Model can be customized in the Profile Model to suit the specific context of the profile. Finally, additional references are included to provide links to related resources or controls.

2) **Implementation Layer:** The Implementation Layer details the practical application of the selected security controls within an organization's information system. It includes two primary models:

   a) The **Component Definition Model** is designed to describe the components of a system and how they implement security controls. This model includes detailed information about the system's architecture, individual components, and the specific controls each component implements. Components can be hardware, software, services, policies, processes, or procedures. The model allows for the definition of a set of components, each providing a description of the controls supported by a specific implementation.

   b) The **System Security Plan (SSP)** Model provides a comprehensive overview of the security controls implemented within a system. It allows the security implementation of an information system to be defined using an OSCAL profile (or baseline) as the basis for the system's control implementation. The SSP model includes highly granular content, such as points of contact, system characteristics, and descriptions of how controls are satisfied.

3) **Assessment Layer:** This layer is designed to describe how security assessments are planned, performed, and reported. This layer includes three primary models:

   a) The **Assessment Plan (AP) Model** represents the information contained within an assessment plan. It is typically used by anyone planning to perform an assessment or continuous monitoring activities on an information system to determine the degree to which that system complies with a given control baseline.

   b) The **Assessment Results (AR) Model** documents the findings of an assessment. It includes detailed information about the assessment activities, evidence collected, and analysis of the effectiveness of the controls. This model helps in understanding the current security posture of the system and identifying areas for improvement.

   c) The **Plan of Actions and Milestones (POA&M) Model** represents the known risks for a specific system, as well as the identified deviations, remediation plans, and the disposition status of each risk. This model is used to document and track the remediation of findings identified during the assessment. It includes details about the findings, the actions to be taken, and the milestones for completing those actions.

One of the primary benefits of OSCAL is its ability to standardize and automate the documentation and assessment of security controls. By using machine-readable formats, OSCAL replaces traditional, manual, and text-based approaches, which can be time-consuming and prone to errors. This standardization enhances accuracy and consistency, making it easier to achieve faster approvals and streamline compliance processes. Additionally, OSCAL supports multiple regulatory frameworks simultaneously, such as NIST SP 800-53 [i.40] and ISO/IEC 27001 [i.41], and PCI DSS (Payment Card Industry Data Security Standard), allowing organizations to manage compliance across various standards more efficiently.

However, OSCAL also has some limitations. One of the main challenges is the initial learning curve and the need for organizations to adapt their existing processes to integrate OSCAL effectively. This transition can require significant time and resources, especially for organizations that are heavily reliant on traditional methods. Furthermore, while OSCAL aims to reduce complexity, it can introduce new complexities, particularly for smaller organizations that may lack the technical expertise to implement and maintain OSCAL-based systems. The need for specialized tools and training can also be a barrier to adoption.

Despite these challenges, the potential benefits of OSCAL make it a valuable tool for enhancing security compliance and assessment processes. Its ability to facilitate interoperability and automation can lead to more efficient and effective security management. As more organizations adopt OSCAL, its community-driven development approach is likely to address many of its current limitations, making it an increasingly robust and versatile framework for security control assessment.

### 4.4.2 Security Content Automation Protocol (SCAP)

The Security Content Automation Protocol (SCAP) [i.29] is a framework developed and maintained by the NIST to standardize the automation of vulnerability management, measurement, and policy compliance evaluation across information systems. SCAP enables organizations to systematically assess, monitor, and enforce security configurations by providing a set of specifications for expressing and sharing security content in a machine-readable format. It has been widely adopted in both federal and commercial environments to improve the efficiency, accuracy, and consistency of security assessments.

SCAP is composed of multiple interrelated standards that collectively allow organizations to evaluate system configurations, identify vulnerabilities, and maintain compliance. Key components include:

- Common Vulnerabilities and Exposures (CVE) [i.30]: A standardized dictionary of publicly known cybersecurity vulnerabilities, providing unique identifiers that allow consistent tracking and communication of vulnerability information across tools and organizations.
- Common Configuration Enumeration (CCE) [i.31]: Provides unique identifiers for system security configuration issues, enabling standardized reporting and assessment of configuration settings.
- Common Platform Enumeration (CPE) [i.32]: A structured naming scheme for hardware, operating systems, and applications that enables precise identification of IT assets for automated security assessments.
- Common Vulnerability Scoring System (CVSS) [i.33]: Provides a standardized method for rating the severity of vulnerabilities, facilitating prioritization of remediation activities.
- Extensible Configuration Checklist Description Format (XCCDF) [i.34]: Defines a standardized format for expressing security checklists and benchmarks, including automated evaluation criteria.
- Open Vulnerability and Assessment Language (OVAL) [i.35]: Provides a standard language for representing system state tests, enabling automated assessment of vulnerabilities, configuration issues, and compliance requirements.
- Asset Reporting Format (ARF) [i.36]: Defines a standardized format for reporting the results of SCAP assessments, enabling interoperability between assessment tools and security management platforms.

SCAP enables organizations to automate the assessment of security controls and configuration policies by integrating these standards into security tools and processes. By providing machine-readable content, SCAP reduces manual effort, increases consistency, and supports continuous monitoring of compliance with policies and benchmarks. Automated SCAP assessments can generate actionable reports for IT administrators, security teams, and auditors, detailing vulnerabilities, misconfigurations, and adherence to security policies.

SCAP version 2 represents an evolution of the framework, addressing some of the limitations of the earlier version while introducing new capabilities. One of its most notable improvements is expanded endpoint coverage. Unlike SCAP v1, which primarily focused on desktops, laptops, and servers, SCAP v2 explicitly includes network devices, mobile endpoints, and IoT systems. This broader scope is complemented by enhanced interoperability through a modular and extensible architecture, allowing for better integration between assessment components and external security tools. The shift from Common Platform Enumeration (CPE) to SWID tags improves software versioning and patch tracking, and protocols such as ROLIE facilitate the acquisition and reuse of SCAP content.

An emerging and promising development in the SCAP ecosystem is its relationship with OSCAL. By bridging endpoint assessment and organizational security governance, OSCAL enhances the value of SCAP v2, though the full potential of this integration depends on widespread adoption across both SCAP tool vendors and organizations.

# 5 Rationale for a device security passport

## 5.1 Limitations of existing device security descriptors

Existing approaches to documenting and exchanging security-related information about connected devices rely on a variety of specialized descriptors, such as SBOM, HBOM, CBOM, MUD, VEX or VDR. Each of these artefacts addresses a specific aspect of device security and provides valuable information within its intended scope.

However, these descriptors have been developed independently and are typically managed as isolated documents. As a result, they lack a common structure, shared context, and explicit relationships between them. This fragmentation makes it difficult for stakeholders to obtain a coherent and up-to-date view of the overall security posture of a device, particularly when information is produced by different actors across the supply chain.

In addition, most existing descriptors are static or semi-static by design and do not explicitly support continuous updates throughout the device lifecycle. Security-relevant information generated during later phases, such as integration, deployment, operation, and vulnerability handling, is often stored separately or communicated through ad hoc mechanisms. This limits traceability, complicates auditing processes, and increases the operational burden on manufacturers, integrators, and operators.

## 5.2 Need for an integrated and lifecycle-aware approach

The increasing regulatory and operational demands placed on manufacturers and operators of connected devices, notably in the context of the EU CRA, require security information to be not only available, but also traceable, verifiable, and maintainable over time. Compliance with such requirements cannot be achieved through a collection of disconnected documents alone.

What is needed is an integrated approach capable of aggregating heterogeneous security descriptors while preserving their original formats and responsibilities. Such an approach should enable security information to evolve alongside the device, reflecting changes introduced during manufacturing, system integration, deployment, operation, and end-of-life phases.

Furthermore, security information should be consumable by both human stakeholders and automated tools. This implies the need for a structured, machine-readable representation that supports versioning, integrity protection, and clear attribution of responsibility for each piece of information.

These considerations motivate the introduction of a unifying construct that can act as a single reference point for device-related security information without replacing existing, well-established descriptors.

## 5.3 Design principles of a Device Security Passport

Based on the identified limitations and needs, the concept of a DSP emerges as a logical evolution rather than a replacement of existing mechanisms. The DSP is conceived as a structured container that references and contextualizes security-related artefacts associated with a device throughout its lifecycle.

Several design principles underpin this concept. First, the DSP is intended to be descriptor-agnostic, allowing existing formats such as SBOM, MUD, or VEX to be referenced rather than embedded or redefined. This preserves compatibility with existing ecosystems and avoids duplication of information. Second, the DSP is lifecycle-aware, enabling incremental updates as new security evidence becomes available. This supports continuous security assurance and post-market activities, such as vulnerability disclosure and remediation tracking. Third, the DSP emphasizes traceability and accountability by associating security information with responsible parties and by supporting versioning and integrity mechanisms. This is particularly relevant in supply-chain scenarios involving multiple stakeholders with distinct roles and obligations. Finally, the DSP is designed to be extensible, allowing additional types of security information to be incorporated as regulatory requirements, technologies, and threat landscapes evolve.

## 5.4 Considered alternatives and design choices

Several alternative approaches were considered to address the challenges outlined above. One option consists of extending existing descriptors, such as SBOMs, to include additional security and lifecycle information. While this could reduce the number of artefacts, it would also overload formats that were not designed to capture operational, regulatory, or responsibility-related data.

Another approach involves relying solely on centralized databases or proprietary security portals to aggregate device security information. Although such solutions may be effective within closed ecosystems, they raise concerns related to interoperability, vendor lock-in, and long-term sustainability.

In contrast, the Device Security Passport concept aims to strike a balance between integration and flexibility. By acting as a unifying reference rather than a monolithic document, the DSP enables coordinated use of existing standards while providing the necessary structure to support traceability, lifecycle management, and regulatory compliance.

# 6 Device Security Passport specification

## 6.1 Concept and objectives

The DSP is conceived as a structured digital artefact that aggregates and contextualizes security-related information associated with a connected device throughout its lifecycle, as shown in Figure 2. Rather than replacing existing security descriptors, the DSP acts as a unifying reference point that links heterogeneous artefacts produced by different stakeholders. The primary objective of the DSP is to improve transparency and traceability of device security information across the supply chain and operational environments. By providing a single logical entry point to security evidence, the DSP facilitates access to relevant information for manufacturers, integrators, operators, and other interested parties, including regulators and certification bodies.

Another key objective is to support automation. The DSP is intended to be machine-readable, enabling security tools and services to retrieve, process and correlate security information without manual intervention. This capability is essential for large-scale deployments where manual security management is not feasible.

Finally, the DSP aims to support continuous security assurance. Security information evolves over time as vulnerabilities are discovered, mitigations are applied, and configurations change. The passport provides a persistent reference that reflects this evolution, enabling stakeholders to maintain an up-to-date view of the device security posture.

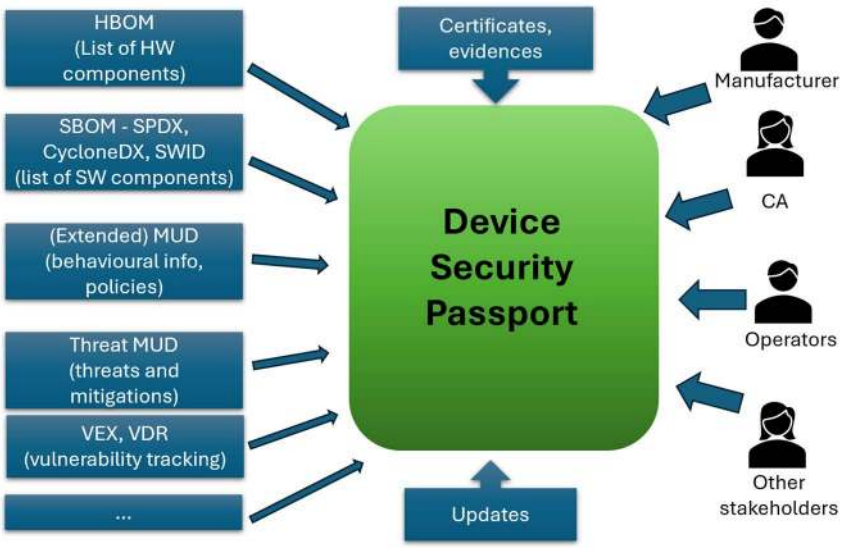



**Figure 2: DSP concept**

## 6.2 Device Security Passport lifecycle

The security posture of a device is not static and evolves throughout its lifecycle. Consequently, the DSP is designed to accompany the device from its initial design and manufacturing phases to its deployment, operation and eventual decommissioning. This lifecycle perspective reflects the natural progression of a device from manufacturing through system integration to operational deployment, as shown in Figure 3. As the device transitions across these stages, its security requirements, ownership context and operating environment evolve. The DSP follows this path, ensuring that security information remains traceable, relevant and consistent throughout the supply chain.

During the design and manufacturing stages, the DSP references baseline security information, establishing the initial security profile of the device (generic DSP or genDSP). This baseline contains static and general security information about the product, such as references to software, hardware and cryptographic components, manufacturer details, vulnerability disclosure mechanisms, expected network behaviour and applicable conformity declarations. For this purpose, standardized formats for security descriptors can be used (e.g. SBOM, HBOM, CBOM, MUD, VEX, VDR). This baseline is cryptographically signed to ensure authenticity and is version-controlled. Manufacturers can update it when new vulnerabilities are discovered or mitigations become available, while maintaining historical records to ensure traceability and continuity. When third parties or users identify vulnerabilities, they may report them to the manufacturer, who can verify the information and update the genDSP accordingly.

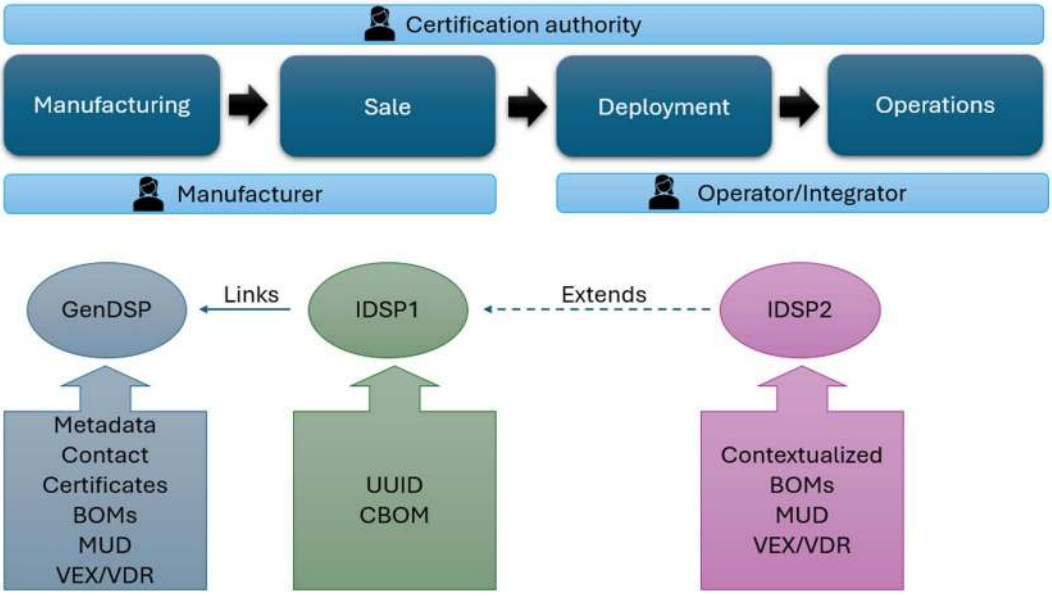



**Figure 3: DSP lifecycle**
**(Source: [i.38])**

As the device moves through the supply chain, this generic security profile becomes associated with individual physical units. At this stage, the DSP is bound to instance-specific information (Instance-level DSP 1 or IDSP1), such as unique device identifiers and cryptographic material required for onboarding. Rather than duplicating baseline content, the instance-level passport references the generic profile, enabling stakeholders to always access the most up-to-date version of the underlying information. Manufacturers may apply granular access controls to both the genDSP and IDSP1, defining which stakeholders can view specific sections. This enables controlled delegation of access to integrators or operators. For example, an integrator who purchases a device may request access to the associated IDSP1.

As devices are integrated into larger systems and deployed in operational environments, additional context-dependent information becomes available. This may include configuration changes, updated network behaviour descriptions, changes in software and hardware composition due to system integration, new vulnerabilities arising from an extended attack surface, and system-specific risk assessments. The DSP evolves accordingly, representing an extension of the IDSP1, referred to as Instance-level DSP 2 (IDSP2).

During the operational phase, the IDSP2 is maintained throughout the device's lifetime, reflecting the actual conditions and security state of a specific unit in its deployment environment. Post-market activities such as vulnerability disclosures, software updates and security incident handling generate new security artefacts. These artefacts can be linked to the DSP to maintain a continuous and traceable security history.

The IDSP2 may also support active security enforcement, such as applying network policies or supplying contextual vulnerability information to monitoring and detection systems.

Like the genDSP, the IDSP2 is inherently updatable. However, while genDSP changes are manufacturer-driven and apply broadly to all devices of the same model, IDSP2 changes are instance-specific and typically initiated by integrators or operators. If an operator considers that a security finding may be relevant to the generic device, they may report this information to the manufacturer to request an update of the genDSP. The manufacturer can then assess the information and determine whether it should be incorporated into the baseline profile, potentially releasing a software update or mitigation to address the vulnerability.

Finally, during decommissioning, the DSP may reference information related to end-of-support declarations, secure disposal procedures or data sanitization activities, completing the lifecycle view of the device. This lifecycle perspective highlights that the DSP is not a static document but a living artefact that evolves in parallel with the device it describes.

In parallel, other stakeholders such as certification authorities and conformity assessment bodies may access the DSP to retrieve relevant security evidence, such as component inventories, vulnerability management information and historical updates. As part of certification workflows, these authorities may also include new information into the passport, including assessment results, compliance statements or certification decisions. This enables the DSP to act not only as a source of evidence, but also as a trusted container for certification-related artefacts enhancing transparency, reducing duplication of effort and reusing certification evidence throughout the lifecycle of the device.

## 6.3 Stakeholders and roles

Multiple stakeholders contribute to and consume information contained in the DSP throughout the device lifecycle. Each stakeholder typically has responsibility for specific aspects of device security and operates within a defined scope of control:

- Manufacturers are generally responsible for providing baseline security information, such as component inventories, development-time security practices and initial vulnerability disclosures. They establish the initial content of the DSP.
- System integrators may introduce additional software components, configurations or deployment-specific security measures. Their contributions reflect how the device is integrated into a larger system context.
- Operators and service providers are responsible for runtime security management, including monitoring, patch deployment and vulnerability remediation. Their activities generate operational security evidence that can be linked to the DSP.
- Third-party security researchers and vulnerability reporters may contribute indirectly by disclosing vulnerabilities to manufacturers or operators, triggering updates to the DSP and improving the overall security posture of the device ecosystem.
- Security assessors, laboratories, regulators or certification bodies, may consume DSP information to support audits, conformity assessments or regulatory oversight, as well as produce security information about audit results and certificate status.
- End users may access selected DSP information to better understand the security characteristics of the devices they operate and to support informed deployment and configuration decisions.

The DSP concept supports this distributed responsibility model by enabling security artefacts to be associated with their originating stakeholders and the lifecycle stages at which they are produced.

# 7 DOSS: Using the DSP for supply chain management

## 7.1 DOSS overview

DOSS project [i.37] elaborates a secure-by-design methodology and implements related technology for complex Internet of Things (IoT) architectures, based on supply chain monitoring, component testing and architecture modelling. The project establishes a "Supply Trust Chain" by integrating key stages of the IoT supply chain into a digital communication loop to facilitate security related information exchange. The technology includes security verification of all hardware and software components of the modelled architecture.

The DOSS protective architecture comprises multiple modules, a component tester, a digital cybersecurity twin, and an architecture security validator. These modules should assure that the software and hardware used are thoroughly tested, the security level of the operating environments are adequately modelled, weaknesses and vulnerabilities are identified and removed, and the eventual architecture designs satisfy related standard requirements. If any weaknesses and vulnerabilities are found this information is fed back to the relevant parties, to the manufacturers or operators. Furthermore, deployment of the components used, and the eventual operation is also covered by the DOSS concept through an automated onboarding platform and the security modules monitoring the runtime environment. Monitoring and integrating the entire supply chain can only be satisfactorily realized if there is efficient, accurate, and timely information exchange between the DOSS modules which assures that all stakeholders of the supply chain - vendors, merchants, integrators and operators - will be aware of the security posture, potential risks of the components they use, and can jointly execute the necessary mitigating actions.

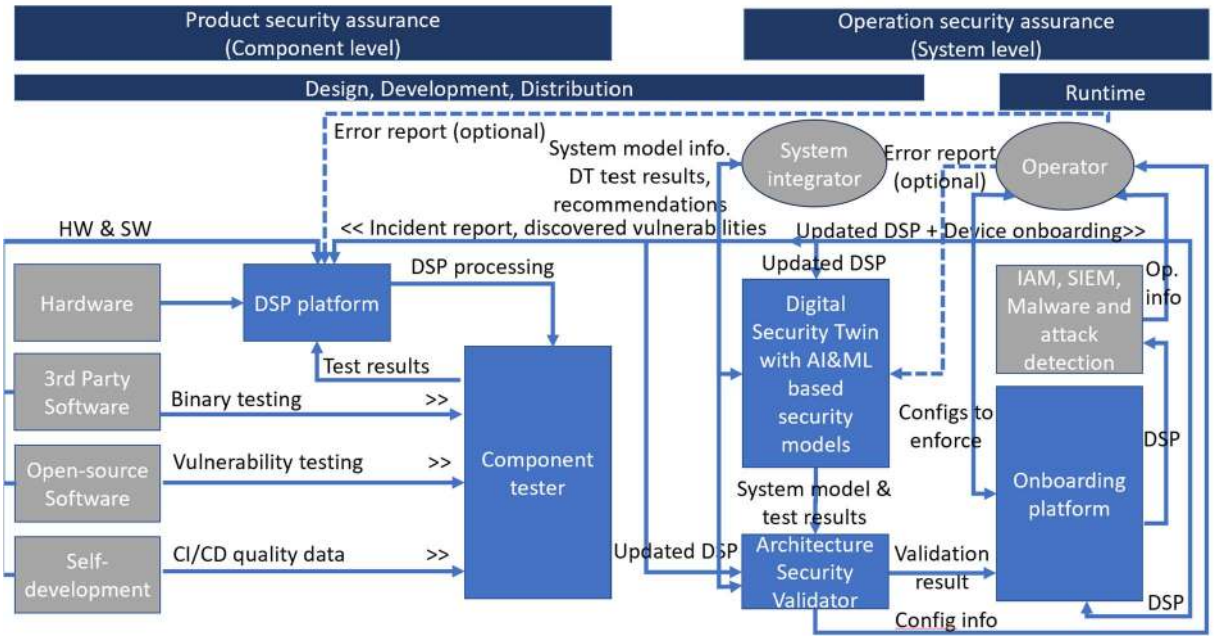



**Figure 4: DOSS architecture (Source: [i.37])**

To facilitate the rapid and reliable information exchange DOSS is implementing a platform, which is the centre piece of the architecture, and provides security related data to all authorized stakeholders regarding the products they use. This platform is called Device Security Passport Platform (DSPP) and is hosting the DOSS DSP of IoT related software and hardware.

Figure 4 shows the entire DOSS architecture and introduces how the modules are interacting with the core DSPP platform and with each other. It can be seen that all actors at all stages of the supply chain are using the DSP information, and the communication is not one sided, but bidirectional. The modules are not only consuming the DSP content, but whenever, at whichever stage of the supply chain some security relevant event is identified related information is fed back to the DSPP and the manufacturers will be able assess the events, take the necessary actions and update the related DSP record. With this fast and efficient, automated information exchange it can be assured that all stakeholders will always have access to all relevant security related information in a timely manner.

## 7.2 The role of the DSP in the DOSS project

Within the DOSS project, the DSP is operationalised as the central information backbone that interconnects all architectural components and stakeholders involved across the supply chain. For this, DOSS deploys a dedicated DSPP that acts as the trusted repository for all DSP records.

The DSP is present in all stages of the DOSS supply chain. During manufacturing, manufacturers create a generic DSP (genDSP) and upload it to the DSPP. Rather than duplicating content, the genDSP stores cryptographically protected metadata and references to externally hosted artefacts (SBOM, CBOM, MUD). Additionally, manufacturers can use the Component Tester (CT) to perform automated vulnerability analysis. The CT retrieves the required information from the DSPP, executes security tests and generates detailed and summary reports. The detailed report is stored on the DSPP and referenced from the genDSP, while summary findings are embedded directly into the passport. Based on these results, manufacturers may release patches, update documentation or publish VEX/VDR artefacts, which are reflected in updated versions of the genDSP.

For each physical device instance, the manufacturer generates an IDSP1 that links to the corresponding genDSP and incorporates instance-specific identifiers (device id) and cryptographic material as a CBOM. The IDSP1 is stored on the DSPP and a link is embedded into the device before release.

During system integration, integrators request access to the IDSP1 through the DSPP. As part of integration activities, they may generate updated artefacts reflecting additional software components, hardware modifications, adapted MUD profiles or newly identified vulnerabilities. These artefacts are stored locally and used to generate an IDSP2, which represents the operational extension of the device context and is maintained in a local DSPP instance.

Integrators provide the IDSP2 to the Digital Cybersecurity Twin (DCT), which uses DSP information to simulate and assess system-level security behaviour. Assessment outputs are forwarded to the Architecture Security Validator (ASV), which performs formal validation. Based on the results, integrators may reconfigure the device, update policies or discontinue its use if risks are unacceptable. Relevant findings can be reported back to the manufacturer, enabling feedback-driven updates to the genDSP and establishing a closed-loop vulnerability management process across the supply chain.

During operation, devices are onboarded using the Onboarding Platform (ObP). Devices provide a link to their DSP, allowing the ObP to retrieve identity material, cryptographic credentials and MUD policies to enforce secure configuration and bootstrapping procedures. Runtime behaviour can be also monitored by DOSS security modules, which compare observed traffic against declared MUD profiles and report deviations to operators.

Operators maintain and update the IDSP2 to reflect contextual vulnerabilities, new configurations and incident records. As in previous phases, relevant findings may be escalated to manufacturers for potential genDSP updates, ensuring continuous improvement of product-level security.

Across all phases, the DSP is used as the shared information interface between DOSS components. The DSPP ensures that updates propagate efficiently and that all actors operate with consistent, trusted and up-to-date security information. Through this implementation, DOSS demonstrates how a DSP can be practically integrated into a secure-by-design supply chain architecture, enabling continuous security assessment, coordinated vulnerability management and lifecycle-driven trust establishment.

## 7.3 DSP data model

In the DOSS project, the DSP data model is based on OSCAL. As discussed in clause 4.4.1 Open Security Control Assessment Language (OSCAL), OSCAL models are highly comprehensive and can represent not only operational security information, but also certification-related data such as security controls, implementation evidence, mitigation plans and system composition. However, using OSCAL in its full form introduces significant complexity and a steep learning curve. Moreover, many of its constructs exceed the current scope of DOSS, which focuses primarily on supply-chain security management.

For this reason, the DSP model used in DOSS has been defined as a simplified OSCAL profile, tailored to the needs of the project. Instead of adopting the complete OSCAL ecosystem, DOSS primarily relies on the SSP model to capture device-specific information such as SBOMs, MUD profiles and technical documentation, and on the AR model to represent vulnerability findings and test reports, including VEX and VDR artefacts. This approach allows DOSS to retain OSCAL compatibility while significantly reducing modelling complexity.

The DSP structure is rooted in the POA&M model, which is used as a logical container to interconnect all security-related artefacts. POA&M was selected as the structural backbone because of its ability to link multiple OSCAL models and external resources while supporting risk tracking and mitigation workflows, as shown in Figure 5.

Following the approach of IoTPass project [i.38], external security descriptors such as SBOMs, HBOMs, CBOMs, MUD profiles, Threat-MUD artefacts, VEX and VDR documents are not embedded directly into the DSP. Instead, they are referenced through explicit links. This design decision allows each descriptor to evolve independently without requiring regeneration of the entire passport. It also preserves ownership and accountability, as each artefact remains under the control of its original author. This decoupling between device information and security artefacts aligns with best practices recommended by initiatives such as CycloneDX, recognizing that security data changes more frequently than device composition.

Where necessary, the OSCAL structure has been extended with DSP-specific fields to capture transparency information required by regulations such as the CRA that are not natively represented in existing OSCAL models. At the same time, redundant OSCAL fields have been removed when equivalent information is already provided by external descriptors, avoiding duplication and inconsistency.

At a high level, the DSP data model is organized around the following building blocks:

- The DSP identifier and metadata form the entry point of the model. Each DSP is uniquely identified using a UUID compliant with IETF RFC 4122 [i.39]. The metadata section provides contextual information such as document version, revision history, last update date, responsible parties and references to supporting documentation, including EU Declarations of Conformity. For instance-level passports, the metadata also contains a reference to the associated generic DSP, ensuring traceability across lifecycle layers.

- The System ID block stores the unique identifier of the physical device instance and is mandatory for instance-level DSPs.

- The Local definitions block consolidates information describing both the device and its security posture. It includes component descriptions, assessment platforms and assessment results, as well as operational observations and identified risks. Within this block, the components subfield captures the type, purpose and status of each element, linking to external artefacts such as SBOMs, HBOMs, CBOMs and MUD files. The CBOM is mandatory at IDSP1 level, as it provides cryptographic material that binds the passport to a specific device instance. The local definitions block also includes an observations section, used to document findings generated during testing or operation, including collection methods, supporting evidence, validity periods and references to detailed reports. Complementing this, the risks section records vulnerabilities and threats, their status, severity indicators, remediation actions (including those derived from Threat-MUD artefacts) and responsible stakeholders.

An optional Imports block allows external OSCAL documents to be referenced directly when available. This enables security assessments and evidence to be reused in their native OSCAL format without duplication. When no imported model exists, equivalent information can be captured within the local definitions block.

Although the DOSS DSP uses a simplified OSCAL profile, the model has been designed to remain extensible. This allows future incorporation of additional OSCAL constructs, for example to support certification workflows, without breaking compatibility with existing passports.

Given that DSP files may influence device configuration and security decisions, they are treated as sensitive artefacts. To ensure integrity and prevent tampering, all DSP instances are digitally signed. Following the MUD security model, signature references are stored within the metadata section. Before a DSP is processed, its signature should be retrieved and validated. Responsibility for signing remains with the passport owner, typically the manufacturer for genDSPs and integrators or operators for instance-level DSPs.

Details of the JSON representations are provided at https://forge.etsi.org/rep/mts/specifications/tr-104-285/-/tree/v1.1.1/schema?ref_type=tags.

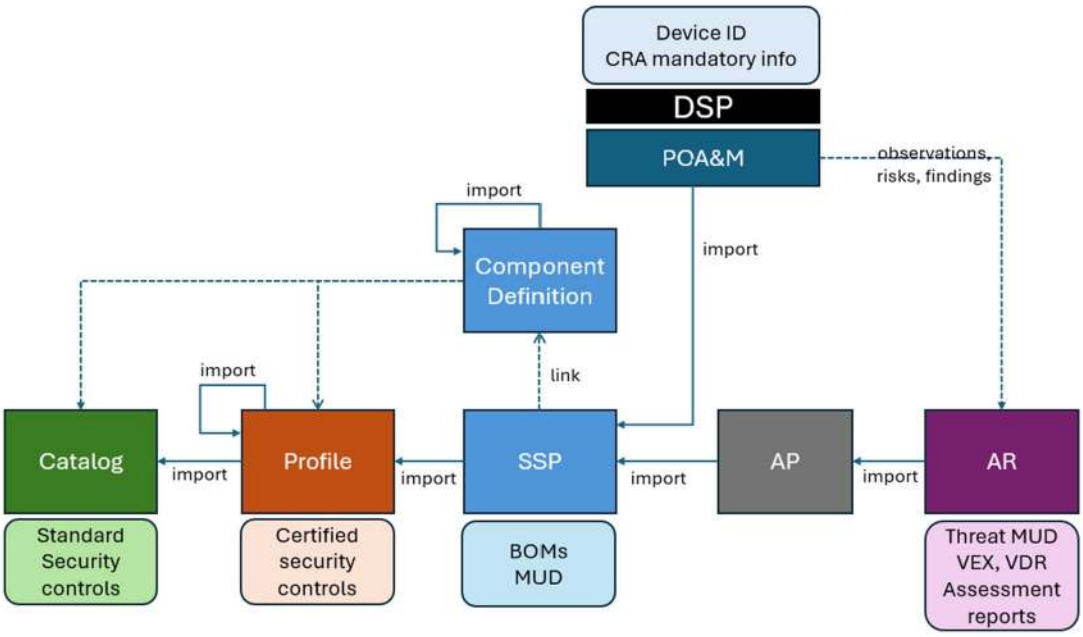



**Figure 5: DSP Schema used in DOSS**
**(Source: [i.38])**

# 8 Role of the Device Security Passport in regulatory context

## 8.1 Alignment with the Cyber Resilience Act (CRA)

The European Union's CRA [i.1] represents a significant shift in the regulatory landscape, introducing lifecycle-oriented cybersecurity obligations for manufacturers of digital products. Its core objective is to enforce a security-by-design and security-by-default approach, requiring transparent documentation, proactive risk management and continuous post-market support.

The DSP provides a coherent framework to support systematic compliance with CRA requirements. Instead of relying on a fragmented set of documents, the DSP consolidates compliance evidence into a single, structured and evolvable digital artefact. The following points illustrate how specific DSP components address key CRA mandates:

- **Manufacturer transparency and vulnerability disclosure:** The CRA requires clear identification of the economic operator and accessible channels for vulnerability reporting. The DSP supports this requirement through its *Metadata/Parties* section, which records manufacturer identity and contact information. In addition, *Metadata/Links* can reference the manufacturer's coordinated vulnerability disclosure policy, providing an explicit and verifiable reporting path for security researchers and users.

- **Product identification and traceability:** To ensure accountability across the supply chain, the CRA mandates unique product identification. The DSP addresses this through a dual mechanism: the *System ID* element, which uniquely identifies individual device instances (in IDSP), and the *Local Definitions/Component* section, which records product name, type and model. This approach supports traceability both at product-family level and at individual device level.

- **Documentation of functionality and security properties:** Manufacturers are required to document the intended purpose, essential functions and security properties of their products. High-level descriptions can be captured within *Local Definitions/Component*, while the DSP's extensible design allows *Metadata/Links* to reference external technical documentation. This keeps the passport lightweight while ensuring full transparency regarding device capabilities and inherent security characteristics.

- **Risk assessment and communication:** A central CRA obligation is the assessment and transparent communication of foreseeable cybersecurity risks. The DSP operationalizes this requirement through its *Local Definitions/Risks* section, where manufacturers can provide structured descriptions of identified risks and potential misuse scenarios. This section can also reference VEX and VDR artefacts, enabling stakeholders to understand whether known vulnerabilities are exploitable in a specific product context. This supports evidence-based risk communication and demonstrates proactive security management.

- **Ongoing support and lifecycle management:** The CRA requires clear communication regarding the duration of security support, update mechanisms and secure decommissioning procedures. The DSP supports these obligations through *Metadata/Links*, which can reference policies related to updating strategies, support timelines and end-of-life procedures. For secure operational practices, *Local Definitions/Components/Links* may reference MUD files to guide secure network configuration, while *Local Definitions/Risks/Remediations/Links* can point to Threat-MUD artefacts, providing dynamic guidance for mitigating emerging threats during operation.

- **Software and hardware transparency:** The CRA requirement for a SBOM is directly supported by the DSP architecture. The *Local Definitions/Components/Links* section provides dedicated references to SBOMs, HBOMs and CBOMs. This enables verifiable visibility into software composition and hardware supply chains, which is essential for integrity assessment and component-level vulnerability management.

- **Declaration of conformity:** To complete the compliance picture, the DSP supports referencing the EU Declaration of Conformity through *Metadata/Links*. This provides auditable evidence that the product complies with the essential requirements of the CRA and other applicable regulations.

## 8.2 Alignment with the NIS2 directive

The NIS2 Directive [i.2] establishes cybersecurity risk management and incident reporting obligations for essential and important entities operating critical and digital services. While the NIS2 Directive primarily targets organizations rather than products, the Device Security Passport can act as a key enabler to support organizational compliance.

The DSP contributes to NIS2 objectives in the following ways:

- **Risk management and security measures:** NIS2 requires organizations to implement appropriate technical and organizational security measures. By aggregating device-level security information, the DSP provides operators with structured visibility into asset composition, vulnerabilities and configuration states. This supports risk-based decision making and the implementation of proportionate security controls.

- **Supply-chain security:** NIS2 places strong emphasis on supply-chain risk management. The DSP supports this requirement by providing traceability of device components, software dependencies and manufacturer information through SBOM, HBOM and CBOM references. This enables organizations to assess supplier-related risks and dependencies in a systematic manner.

- **Incident handling and reporting:** Operators subject to NIS2 should detect, respond to and report significant cybersecurity incidents. The DSP facilitates incident analysis by maintaining historical records of vulnerabilities, patches and configuration changes. This contextual information supports root-cause analysis and structured incident reporting to competent authorities.

- **Business continuity and resilience:** By providing visibility into device security posture and lifecycle status, the DSP supports operational resilience planning. Information on support timelines, update availability and end-of-life status helps organizations anticipate risks and maintain service continuity.

## 8.3 Alignment with the CSA

The EU CSA [i.3] establishes a European cybersecurity certification framework for ICT products, services and processes. In this context, the Device Security Passport can support certification activities by acting as a structured container for security evidence and assessment artefacts.

The DSP aligns with CSA objectives in the following ways:

- **Support to certification schemes:** Certification schemes require structured evidence regarding product security properties, development practices and vulnerability management processes. The DSP provides a centralized reference point for such evidence, including security documentation, vulnerability handling policies and lifecycle management procedures.
- **Traceability of assessment results:** Certification assessments generate reports, findings and compliance statements. These artefacts can be referenced or embedded in the DSP, ensuring traceability between certified requirements and supporting evidence.
- **Post-certification monitoring:** The CSA promotes continuous assurance beyond initial certification. The DSP enables post-certification monitoring by tracking vulnerability disclosures, software updates and configuration changes that may affect certified security claims.
- **Reuse of certification evidence:** By maintaining certification artefacts in a structured and machine-readable format, the DSP facilitates reuse of evidence across different certification schemes or regulatory processes, reducing duplication of effort.

# 9 Lessons learned and recommendations

A major challenge identified throughout the present document is the fragmentation of existing security descriptors. Artefacts such as SBOM, HBOM, MUD, VEX and VDR have evolved independently, resulting in heterogeneous formats and governance models. This fragmentation makes it difficult to obtain a holistic and up-to-date view of device security. The present document confirms the need for a common aggregation mechanism capable of centralizing references to these artefacts while preserving their original formats and ownership.

In this context, the experience gained through the design and implementation of the DSP highlights several important lessons and areas for improvement. One fundamental lesson learned is the importance of machine-readability. Human-readable documentation alone is no longer sufficient to support modern cybersecurity operations. The DSP demonstrates the value of structured, machine-readable artefacts to enable automation, continuous monitoring, dynamic policy enforcement and regulatory reporting.

From a data modelling perspective, the use of OSCAL as a foundation has proven to be a sound technical choice. As discussed in clause 4.4.1Open Security Control Assessment Language (OSCAL), OSCAL offers a highly flexible and expressive framework capable of representing not only the information required for the supply chain management, but also certification-related artefacts such as security controls, mitigation plans and assessment evidence. However, OSCAL "as it is", is not sufficient to fully support emerging regulatory and certification process. Extensions were required in DOSS to capture transparency data mandated by frameworks such as the CRA and additional extensions may be needed to represent certification-related information, such as metrics linked to security controls or certificate status.

Practical adoption has shown that using OSCAL in its full form introduces significant complexity and a steep learning curve. Even with a simplified profile, the generation and maintenance of DSPs remains a non-trivial task. This reveals the need for supporting tools to automate data extraction, DSP generation and updates. In this context, emerging technologies such as Large Language Models and AI-based assistants could play a relevant role by supporting information extraction, correlation and structuring, reducing manual effort and potential errors.

The layered lifecycle model adopted in the DSP, separating baseline information from instance-level and operational data, has proven to be aligned with real-world responsibilities. Manufacturers, integrators and operators manage different aspects of device security at different stages, and the DSP should reflect this distributed governance model. This reinforces the importance of supporting multiple layers managed by different stakeholders before and after deployment.

Data governance and access control have also emerged as critical aspects. DSPs may contain sensitive information related to vulnerabilities, cryptographic material or operational configurations. A balance should therefore be found between transparency and confidentiality. Fine-grained access control mechanisms, authentication, authorization and clear data-sharing policies are required to regulate how, when and by whom information is accessed and reused.

Finally, the structured nature of the DSP opens new opportunities for advanced analytics and artificial intelligence. By acting as a trusted knowledge source, the passport can support automated vulnerability detection, risk assessment, security testing and even certification processes. This represents a promising research and industrial direction for future developments.

# History

| Version | Date | Status |
|---|---|---|
| V1.1.1 | August 2026 | Publication |
| | | |
| | | |
| | | |
| | | |